

# **PROGRAMME DE SENSIBILISATION À LA CYBERSÉCURITÉ**

## **CLINISANTÉ SAS**

Dossier présenté au Comité de Direction  
NEXA Digital School – Projet de Sensibilisation des Utilisateurs

Juin 2025

# 1. Résumé Exécutif

---

La mission de CLINISANTÉ SAS est de fournir des soins ambulatoires et des diagnostics médicaux de qualité à ses patients, dans le respect des exigences réglementaires les plus strictes (RGPD, HDS, NIS 2). Pour soutenir cette mission, le système d'information de CLINISANTÉ s'appuie sur des technologies critiques traitant des données de santé à caractère personnel particulièrement sensibles.

**Problème :** Les incidents survenus récemment au sein de CLINISANTÉ révèlent que le facteur humain constitue le principal vecteur de risque cyber. En cinq semaines, l'organisation a subi un phishing ciblant les RH (credentials Silae compromis, 40 salariés exposés), une connexion USB suspecte sur équipement biomédical, et un signalement CNIL lié à des transferts de données non conformes. Ces événements s'inscrivent dans un contexte où aucune campagne de phishing simulé n'a jamais été organisée, où le taux de complétion du module e-learning d'intégration est de seulement 68 %, et où le budget formation cybersécurité est de 3 000 € pour toute la DSI.

**Solution :** La mise en œuvre d'un Programme de Sensibilisation à la Cybersécurité structuré permettra de modifier les comportements du personnel et de construire une culture de sécurité durable. Ce programme ne remplace pas les contrôles techniques existants (pare-feu Fortinet, EDR SentinelOne, SIEM Splunk), il les complète en comblant le gap humain.

**Valeur :** Ce programme permettra à CLINISANTÉ de : réduire le risque d'incidents d'origine humaine, satisfaire aux obligations NIS 2 et RGPD, protéger la réputation de l'établissement, et pérenniser la confiance des patients et des partenaires.

## 2. Objectifs de Sensibilisation

---

### 2.1 Objectifs Stratégiques

Le programme de sensibilisation de CLINISANTÉ poursuit quatre objectifs stratégiques alignés sur les priorités de direction :

- **Réduire le risque humain** : diminuer de 60 % le taux de clic sur les campagnes de phishing simulé dans les 12 mois suivant le démarrage du programme.
- **Assurer la conformité réglementaire** : répondre aux exigences de formation imposées par NIS 2 (entité importante), le RGPD et le référentiel HDS.
- **Construire une culture de sécurité** : faire de chaque collaborateur un acteur conscient et responsable de la protection des données de santé.
- **Améliorer la détection et le signalement** : augmenter de 80 % le nombre d'incidents signalés spontanément par les utilisateurs au RSSI.

### 2.2 Objectifs Opérationnels

- Atteindre 100 % de complétion du module e-learning obligatoire (vs 68 % actuellement)
- Organiser au moins 3 campagnes de phishing simulé par an
- Former 100 % des personnels médicaux et paramédicaux (actuellement : zéro formation dédiée)
- Sensibiliser la Direction Générale et le Conseil d'Administration aux risques cyber
- Mettre à jour la Charte informatique (non révisée depuis 2019) et en assurer la diffusion

## 3. Populations Cibles et Messages Clés

### 3.1 Cartographie des Populations

CLINISANTÉ emploie 220 collaborateurs répartis sur deux sites (Montpellier : 180, Sète : 40) avec environ 15 % en télétravail. L'analyse des risques identifie cinq populations cibles distinctes :

| Population                          | Effectif | Niveau de risque                  | Principaux risques identifiés                                                                                  |
|-------------------------------------|----------|-----------------------------------|----------------------------------------------------------------------------------------------------------------|
| Personnels médicaux et paramédicaux | ~120     | <input type="checkbox"/> Critique | Phishing ciblé (données patients)<br>Shadow IT (Dropbox non autorisé)<br>Partage non conforme de données DICOM |
| Personnels administratifs et RH     | ~50      | <input type="checkbox"/> Critique | Phishing (incident Silae avéré)<br>Gestion des mots de passe<br>Traitement données paie                        |
| Direction Générale et CODIR         | ~10      | <input type="checkbox"/> Élevé    | Whaling / BEC (Business Email Compromise)<br>Confidentialité des décisions stratégiques                        |
| Équipe DSI et techniciens           | ~10      | <input type="checkbox"/> Élevé    | Accès privilégiés<br>Gestion des prestataires<br>Shadow IT                                                     |
| Prestataires et télétravailleurs    | ~30      | <input type="checkbox"/> Modéré   | Accès VPN non sécurisés<br>Équipements personnels non conformes                                                |

### 3.2 Messages Clés par Population

#### Personnels médicaux et paramédicaux

- « Vos patients vous font confiance — protégez leurs données comme vous protégez leur santé »
- Ne jamais partager des images DICOM ou des comptes-rendus médicaux via des outils non homologués (OneDrive personnel, Dropbox, e-mail non chiffré)
- Signaler immédiatement tout comportement anormal sur un équipement médical ou toute clé USB inconnue
- La téléconsultation impose les mêmes règles de confidentialité qu'une consultation en présentiel

#### Personnels administratifs et RH

- « Un clic sur un lien malveillant peut exposer les données de paie de tous vos collègues » (référence à l'incident Silae)
- Vérifier systématiquement l'expéditeur avant de cliquer — votre outil de paie ne vous demandera jamais vos identifiants par e-mail
- Utiliser des mots de passe uniques et activer le MFA dès que disponible

- Ne jamais traiter de données RH sur des équipements personnels non approuvés

### **Direction Générale et CODIR**

- Les cadres dirigeants sont des cibles prioritaires des attaquants (whaling, fraude au président)
- La cybersécurité est un sujet de gouvernance, pas seulement technique — NIS 2 engage la responsabilité des dirigeants
- Valider et soutenir la PSSI, actuellement non présentée au CODIR depuis 2020

### **Équipe DSI**

- Rigueur dans la gestion des accès prestataires (TechSupport Pro, BioMed Services)
- Traçabilité des connexions USB sur les équipements biomédicaux
- Revue régulière des droits d'administration de domaine (comptes de service sur-privilégiés)

### **Télétravailleurs**

- Utilisation obligatoire du VPN pour tout accès aux ressources internes
- Ne pas travailler sur des réseaux Wi-Fi publics sans VPN actif
- Signaler tout incident de sécurité même depuis le domicile

## 4. Planification du Programme

### 4.1 Vue d'Ensemble — Programme sur 12 Mois

| Trimestre       | Actions                                                                                                                                                                                                                                      | Populations visées                                        | Format                                         | Livrables                                              |
|-----------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------|------------------------------------------------|--------------------------------------------------------|
| T1 (Mois 1-3)   | Lancement officiel du programme<br>Mise à jour Charte informatique<br>Module e-learning fondamental (phishing, mots de passe, données de santé)<br>Campagne de phishing simulé #1 (baseline)<br>Sensibilisation CODIR/DG (session dédiée 1h) | Tous les collaborateurs (220) Priorité : Admin/RH + CODIR | E-learning<br>Présentiel DG<br>Phishing simulé | Taux de clic baseline<br>Taux de complétion e-learning |
| T2 (Mois 4-6)   | Ateliers thématiques en présentiel (2h) par population<br>Focus médecins : données DICOM, Shadow IT<br>Focus RH/Admin : phishing, credentials<br>Affiches et communications internes<br>Campagne de phishing simulé #2                       | Personnels médicaux<br>Personnels admin/RH                | Atelier<br>Affichage<br>Phishing simulé        | Réduction taux de clic<br>Audit Shadow IT              |
| T3 (Mois 7-9)   | Module e-learning avancé (NIS 2, HDS, télétravail sécurisé)<br>Exercice de simulation de crise cyber (tabletop)<br>Formation prestataires (TechSupport Pro, BioMed)<br>Campagne de phishing simulé #3                                        | DSI + CODIR<br>Prestataires<br>Télétravailleurs           | E-learning<br>Tabletop<br>Phishing simulé      | Rapport simulation<br>Suivi prestataires               |
| T4 (Mois 10-12) | Bilan annuel et rapport au CODIR<br>Révision du programme pour N+1<br>Campagne de communication fin d'année<br>Mise à jour matrice des risques humains                                                                                       | Tous CODIR/DG                                             | Rapport<br>Communication                       | Rapport KPI<br>Plan N+1                                |

## 4.2 Calendrier Détaillé — Semestre 1

| Mois   | Action                                                                        | Responsable          | Statut   |
|--------|-------------------------------------------------------------------------------|----------------------|----------|
| Mois 1 | Kick-off programme : réunion de lancement CODIR + communication all-staff     | RSSI + DRH           | Planifié |
| Mois 1 | Mise à jour et diffusion de la Charte informatique (version 2025)             | RSSI + DRH + DQC     | Planifié |
| Mois 2 | Déploiement module e-learning obligatoire via LMS (plateforme à sélectionner) | DSI + DRH            | Planifié |
| Mois 2 | Campagne phishing simulé #1 — mesure baseline (taux de clic, signalement)     | RSSI                 | Planifié |
| Mois 3 | Session dédiée Direction Générale et CA : enjeux cyber, responsabilité NIS 2  | RSSI + DGD           | Planifié |
| Mois 4 | Ateliers présentiel médecins (Montpellier + Sète) : données DICOM, Shadow IT  | RSSI + DMed          | Planifié |
| Mois 5 | Ateliers présentiel admin/RH : phishing avancé, gestion des credentials       | RSSI + DRH           | Planifié |
| Mois 5 | Déploiement affiches sensibilisation (sites Montpellier + Sète)               | RSSI + Communication | Planifié |
| Mois 6 | Campagne phishing simulé #2 + rapport d'avancement CODIR (T1-T2)              | RSSI                 | Planifié |

## 4.3 Gouvernance du Programme

- Pilote du programme : RSSI (M. Thomas Viala) avec rattachement fonctionnel à la DGD (Mme Claire Ségur)
- Co-pilotes : DRH (recrutement, onboarding), DQC (conformité RGPD/NIS 2), DMed (personnels soignants)
- Comité de pilotage : trimestriel, réunissant RSSI, DGD, DRH, DQC — rapport au CODIR
- Escalade : tout incident lié à un comportement humain doit être remonté au RSSI dans les 24h

## 5. Exemple Concret de Sensibilisation

### 5.1 Affiche de Sensibilisation — Anti-Phishing

☐ **CLINISANTÉ — ALERTE PHISHING**  
Votre vigilance protège vos patients

☐ **Comment reconnaître un e-mail de phishing ?**

- ◆ Expéditeur inconnu ou adresse e-mail suspecte (ex : silae-support@gmail.com)
- ◆ Demande urgente de saisir vos identifiants ou mots de passe
- ◆ Lien qui ne correspond pas à l'adresse du site (survolez avant de cliquer !)
- ◆ Pièce jointe inattendue (.zip, .exe, .docm...)
- ◆ Fautes d'orthographe, ton inhabituel, demande de confidentialité

☒ **Que faire si vous avez un doute ?**

1. **NE PAS cliquer sur le lien ou ouvrir la pièce jointe**
2. Signaler immédiatement à : [rssi@clinisante.fr](mailto:rssi@clinisante.fr) / Tél. interne : 555
3. **NE PAS effacer le message** (le conserver pour analyse)
4. Si vous avez cliqué : changer votre mot de passe immédiatement et appeler le RSSI

☐ **RAPPEL : L'incident de phishing Silae a exposé les données de paie de 40 collègues.**  
**Votre vigilance est notre première ligne de défense.**

### 5.2 Extrait de Module E-Learning : Quiz Anti-Phishing

Le module e-learning proposé s'appuie sur 5 scénarios contextualisés à l'environnement CLINISANTÉ. Voici un exemple de scénario interactif :

#### SCÉNARIO 2 — E-mail reçu ce matin :

De : support-silae@rh-portail.net

Objet : ☐ ACTION REQUISE — Votre accès Silae expirera dans 2h

Bonjour, votre session Silae est sur le point d'expirer. Cliquez ici pour renouveler vos accès : <http://silae-renew.rh-portail.net/login>

#### Que faites-vous ?

A) Je clique rapidement pour ne pas perdre mon accès

**B) Je signale l'e-mail au RSSI et j'attends sa réponse**

C) Je transfère l'e-mail à mon responsable pour avis

D) Je l'ignore et le supprime

☒ **Bonne réponse : B — Indices : domaine @rh-portail.net ≠ silae.fr officiel ; urgence artificielle ; lien suspect. Toujours signaler avant d'agir.**





## 6. Solutions Complémentaires — Benchmark

### 6.1 Critères de Sélection

La sélection des outils complémentaires de sensibilisation s'appuie sur les critères suivants, pondérés selon le contexte CLINISANTÉ :

- Conformité réglementaire : hébergement des données en UE, RGPD-compliant, certification HDS si données de santé traitées
- Pertinence sectorielle : contenus adaptés au secteur de la santé (médecins, infirmiers, administratifs)
- Facilité de déploiement : intégration avec Microsoft 365 / Azure AD (SSO), déploiement sans infrastructure lourde
- Fonctionnalités phishing : simulation de campagnes de phishing avec reporting détaillé
- Coût : adapté à un budget PME (budget formation DSI actuel : 3 000 € — extension budgétaire requise)
- Support francophone : interface et contenus disponibles en français

### 6.2 Benchmark des Solutions

| Solution                                | Éditeur                        | Points forts                                                                                       | Limites                                                                      | Coût estimé (220 users) | Adéquation CLINISANTÉ                  |
|-----------------------------------------|--------------------------------|----------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------|-------------------------|----------------------------------------|
| Proofpoint Security Awareness Training  | Proofpoint (US)                | Contenus très riches<br>Simulation phishing avancée<br>Intégration M365<br>Templates secteur santé | Tarif élevé<br>Interface en anglais (FR limité)<br>Complexité de déploiement | ~15 000–20 000 €/an     | *** Bon mais coûteux                   |
| KnowBe4                                 | KnowBe4 (US, héberg. EU dispo) | Leader mondial<br>Phishing simulé +14 000 templates<br>Intégration AD/SSO<br>Rapports détaillés    | Interface principale en EN<br>Hébergement EU en option payante               | ~12 000–18 000 €/an     | **** Excellent, adapter hébergement EU |
| Cyber School Hub (Conscio Technologies) | Conscio (FR)                   | 100% français<br>RGPD natif<br>Contenus santé disponibles<br>Support FR                            | Moins de templates phishing<br>Moins connu à l'international                 | ~8 000–12 000 €/an      | ***** Recommandé — 100% FR et conforme |

| Solution                            | Éditeur                      | Points forts                                                                         | Limites                                                 | Coût estimé (220 users) | Adéquation CLINISANTÉ         |
|-------------------------------------|------------------------------|--------------------------------------------------------------------------------------|---------------------------------------------------------|-------------------------|-------------------------------|
| Usecure                             | usecure (UK, RGPD compliant) | Tarif compétitif<br>Déploiement rapide<br>Phishing simulé inclus<br>Intégration M365 | Contenus santé à personnaliser<br>Moins de templates FR | ~5 000–8 000 €/an       | *** Bon rapport qualité/prix  |
| Riot (sensibilisation individuelle) | Riot (FR)                    | IA personnalisée<br>Micro-learning quotidien<br>Interface intuitive<br>100% FR       | Phishing simulé moins développé<br>Jeune éditeur        | ~6 000–9 000 €/an       | **** Innovant, bon complément |

### 6.3 Solution Recommandée

Au regard du contexte CLINISANTÉ (contraintes RGPD/HDS, effectif 220 personnes, besoin fort de contenus en français, données de santé), la recommandation est la suivante :

**Solution principale :** Cyber School Hub (Conscio Technologies) — plateforme française, 100% RGPD-compliant, avec des modules de phishing simulé et des contenus adaptables au secteur de la santé. Budget estimé : 8 000 à 12 000 €/an.

**Solution complémentaire :** Riot — pour le micro-learning quotidien auprès des personnels médicaux (format court, mobile-friendly, adapté aux contraintes de temps des soignants). Budget estimé : 4 000 à 6 000 €/an.

Budget total recommandé pour le programme complet (plateforme + phishing simulé + micro-learning + ateliers présentiel) : 15 000 à 20 000 €/an, à faire valider par le CODIR dans le cadre du budget NIS 2.

## 7. Indicateurs de Performance (KPI)

### 7.1 KPI de Comportement

| Indicateur                                | Valeur initiale             | Objectif 12 mois  | Moyen de mesure            |
|-------------------------------------------|-----------------------------|-------------------|----------------------------|
| Taux de clic phishing simulé              | Non mesuré (baseline T1)    | < 5 %             | Rapport campagnes phishing |
| Taux de signalement phishing simulé       | Non mesuré                  | > 70 %            | Rapport campagnes phishing |
| Taux de complétion e-learning obligatoire | 68 %                        | 100 %             | LMS — tableau de bord      |
| Nombre d'incidents signalés spontanément  | Très faible (non tracé)     | +80 % vs baseline | SIEM + RSSI                |
| Nombre d'utilisateurs Shadow IT détectés  | Non mesuré                  | Réduction de 50 % | Audit DSI + DLP            |
| Délai moyen de signalement incident       | 4 jours (incident USB Sète) | < 4 heures        | Tickets RSSI               |

### 7.2 KPI de Conformité

| Indicateur                                        | Valeur initiale                   | Objectif 12 mois     | Moyen de mesure          |
|---------------------------------------------------|-----------------------------------|----------------------|--------------------------|
| Charte informatique signée par les collaborateurs | Version 2019 signée à l'embauche  | 100 % (version 2025) | RH — registre signatures |
| PSSI présentée et validée par le CODIR            | Non (dernière version 2020)       | Oui — T1             | PV CODIR                 |
| Formation NIS 2 CODIR/DG complétée                | Aucune                            | 100 % CODIR — T1     | LMS + présence           |
| Personnel médical formé en cybersécurité          | 0 %                               | > 90 %               | LMS                      |
| Prestataires formés et habilités documentés       | Partiel (TechSupport Pro, BioMed) | 100 %                | Registre habilitations   |

### 7.3 KPI de Culture Sécurité

| Indicateur                                  | Valeur initiale | Objectif 12 mois                              | Moyen de mesure          |
|---------------------------------------------|-----------------|-----------------------------------------------|--------------------------|
| Score perception sécurité (enquête interne) | Non mesuré      | Mesure baseline T1<br>Objectif : +20 pts à T4 | Enquête annuelle anonyme |

| Indicateur                               | Valeur initiale | Objectif 12 mois    | Moyen de mesure        |
|------------------------------------------|-----------------|---------------------|------------------------|
| Satisfaction programme sensibilisation   | N/A             | > 75 % satisfaction | Enquête post-formation |
| Nombre de suggestions sécurité remontées | 0               | > 10 / an           | Canal dédié RSSI       |

## 7.4 Reporting et Gouvernance des KPI

- Rapport mensuel RSSI → DSI : suivi des campagnes phishing simulé et incidents
- Rapport trimestriel RSSI → CODIR : tableau de bord KPI complet, plan d'action
- Rapport annuel RSSI → Conseil d'Administration : bilan programme, budget N+1, conformité NIS 2
- Tableau de bord en temps réel : accessible via la plateforme de sensibilisation choisie

## 8. Conclusion et Plan d'Action Immédiat

---

### 8.1 Synthèse

Le Programme de Sensibilisation à la Cybersécurité de CLINISANTÉ répond à une urgence opérationnelle documentée par trois incidents récents majeurs. Il s'inscrit dans les obligations réglementaires NIS 2, RGPD et HDS auxquelles CLINISANTÉ est soumise en tant qu'entité importante du secteur de la santé.

Ce programme structuré sur 12 mois couvre l'ensemble des 220 collaborateurs avec une approche différenciée par population cible, des formats adaptés (e-learning, ateliers présentiel, phishing simulé, micro-learning), et des indicateurs de performance précis permettant de démontrer la valeur au CODIR.

### 8.2 Actions Immédiates — Semaine 1

- **Présentation et validation du programme par la DGD et le CODIR**
- **Sélection de la plateforme de sensibilisation (appel d'offres : Conscio / Riot)**
- **Lancement de la mise à jour de la Charte informatique (RSSI + DRH + DQC)**
- **Planification de la session de sensibilisation dédiée Direction Générale et CA**
- **Définition du budget programme (recommandation : 15 000 – 20 000 €/an)**

### 8.3 Message Final au CODIR

**« La sécurité de nos patients commence par la vigilance de nos collaborateurs.**

**Investir dans la sensibilisation, c'est protéger CLINISANTÉ, ses patients et sa réputation. »**

## Annexe A — Programme Annuel de Sensibilisation (Calendrier Détaillé)

| Mois | Thème principal                    | Format                          | Population         | Livrable                  | KPI associé           |
|------|------------------------------------|---------------------------------|--------------------|---------------------------|-----------------------|
| Jan  | Lancement + Phishing fondamentaux  | E-learning + Phishing simulé #1 | Tous               | Taux de clic baseline     | Taux de clic          |
| Fév  | Charte informatique 2025           | Communication + Signature       | Tous               | 100% signatures           | % signatures          |
| Mar  | Gouvernance cyber — NIS 2          | Session dédiée 1h               | CODIR / DG / CA    | PV validation PSSI        | PSSI validée          |
| Avr  | Shadow IT & données médicales      | Atelier présentiel 2h           | Médecins / Para    | Audit Shadow IT           | Nbre usages détectés  |
| Mai  | Phishing avancé & credentials      | Atelier + Phishing simulé #2    | Admin / RH         | Rapport phishing          | Taux de clic T2       |
| Juin | Télétravail sécurisé               | E-learning + Affiches           | Télétravailleurs   | Guide télétravail         | Taux complétion       |
| Juil | Accès privilégiés & prestataires   | Atelier DSI + Habilitations     | DSI + Prestataires | Registre habilitations    | % prestataires formés |
| Août | Consolidation — module NIS 2 / HDS | E-learning avancé               | Tous               | Taux de complétion        | % complétion          |
| Sep  | Simulation crise cyber (tabletop)  | Exercice CODIR + DSI            | CODIR + DSI        | Rapport exercice          | Délai réponse         |
| Oct  | Mois européen cybersécurité        | Phishing simulé #3 + Comm       | Tous               | Rapport KPI T3            | Taux de clic T3       |
| Nov  | Bilan mi-programme + ajustements   | Rapport CODIR                   | CODIR              | Dashboard KPI             | Tous KPI              |
| Déc  | Bilan annuel + Plan N+1            | Rapport CA + Communication      | CA + Tous          | Rapport annuel + Plan N+1 | Tous KPI              |

## Annexe B — Matrice de Suivi des Risques Humains

| Risque humain                 | Probabilité                     | Impact                            | Incident CLINISANTÉ associé          | Traitement programme                     |
|-------------------------------|---------------------------------|-----------------------------------|--------------------------------------|------------------------------------------|
| Phishing / Ingénierie sociale | <input type="checkbox"/> Élevée | <input type="checkbox"/> Critique | Incident Silae — 40 salariés exposés | Phishing simulé x3/an + atelier admin/RH |

| Risque humain                             | Probabilité                      | Impact                            | Incident CLINISANTÉ associé       | Traitement programme                         |
|-------------------------------------------|----------------------------------|-----------------------------------|-----------------------------------|----------------------------------------------|
| Shadow IT / Usage non autorisé            | <input type="checkbox"/> Élevée  | <input type="checkbox"/> Critique | Dropbox Sète — données patients   | Atelier médecins + audit DSI                 |
| Supports amovibles non contrôlés          | <input type="checkbox"/> Modérée | <input type="checkbox"/> Élevé    | Clé USB BioMed — VLAN 50          | Sensibilisation prestataires + habilitations |
| Mots de passe faibles / partagés          | <input type="checkbox"/> Élevée  | <input type="checkbox"/> Critique | Credentials Silae compromis       | E-learning mots de passe + MFA étendu        |
| Non-signalement d'incidents               | <input type="checkbox"/> Élevée  | <input type="checkbox"/> Élevé    | 4 jours avant remontée RSSI (USB) | Formation signalement + canal dédié          |
| Transferts non conformes données patients | <input type="checkbox"/> Modérée | <input type="checkbox"/> Critique | Signalement CNIL SendGrid         | Atelier RGPD/HDS médecins + DPO              |
| Accès non sécurisé en télétravail         | <input type="checkbox"/> Faible  | <input type="checkbox"/> Élevé    | Pas de MDM équipements personnels | E-learning télétravail sécurisé              |